Seguridad Informática

Deber 3

Integrantes: Juan Pablo Bautista, Daniela Salazar, Ryan de la Torre

Tarea 1

OWASP top 10

Vulnerabilidades	**CWE**	**CVE -2025**	**Impacto**
A01 – Broken Access Control	**CWE-285** Missing Authorization: el sistema no verifica si el usuario tiene permiso antes de ejecutar una acción sensible.	WordPress Plugin: *User Registration & Membership* (< v4.1.2)	Usuarios no autenticados podían asignarse el rol de administrador durante el registro, comprometido completamente la instalación de WordPress. El atacante obtenía control total: instalar plugin maliciosos, robar datos de usuarios y modificar contenido del sitio.
A03 – SQL Injection	**CWE-89** Improper Neutralization of Special Elements in SQL commands: el input del usuario se concatena directamente en consultas SQL sin sanitización	Fortinet *FortiWeb* WAF	Esta falla de inyección SQL no autenticada con CVSS de 9.6 permite ejecutar comandos SQL arbitrarios mediante peticiones HTTP/HTTPS especialmente diseñadas. Afecta a un WAF, el mismo producto que debería defender contra SQLi.
A03- Injection (XSS-Cross-Site Scripting)	**CWE-79** El atacante inyecta código JavaScript que se ejecuta en el navegador de otras víctimas.	Adobe *Experience Manager* (AEM ≤ v11.6)	En Adobe Experience Manager, un usuario con pocos privilegios guardaba JavaScript malicioso en un campo de formulario. Cuando un administrador abría esa página, el script robaba su sesión automáticamente.

Tarea 2

Derechos del titular Según LOPDP

Derecho	**Artículo**	**Significado**
Derecho a la Información	Art 12	El titular tiene derecho a ser informado conforme los principios de lealtad y transparencia sobre el tratamiento de sus datos, incluyendo la identidad y datos de contacto del responsable.
Derecho de Acceso	Art 13	Puedes solicitar en cualquier momento una copia de todos tus datos que una empresa o entidad posea sobre ti.
Derecho de Rectificación y Actualización	Art 14	El titular tiene el derecho a obtener del responsable del tratamiento la rectificación y actualización de sus datos personales inexactos o incompletos, y el responsable deberá atender el requerimiento en un plazo de quince (15) días.
Derecho de eliminación	Art 15	El titular tiene derecho a que el responsable elimine, haga ilegible o dejes irreconocibles de forma definitiva y segura sus datos personales, en un plazo de quince (15) días de recibida la solicitud.
Derecho de Oposición	Art 16	El titular tiene el derecho a oponerse al tratamiento de sus datos, especialmente cuando el tratamiento tenga por objeto la mercadotecnia directa, incluyendo la elaboración de perfiles.
Derecho de Portabilidad	Art 17	Puedes recibir tus datos en un formato estructurado, legible por máquina, y transferirlos a otro responsable del tratamiento.
Derecho a la Limitación del Tratamiento	Art 18	Puedes solicitar que se suspenda temporalmente el uso de tus datos mientras se resuelve una disputa o rectificación.
Derecho a No ser objeto de Decisiones Automatizadas	Art 19	Se reconoce el derecho a no ser objeto de una decisión basada únicamente en el tratamiento automatizado de datos, incluyendo la elaboración de perfiles.

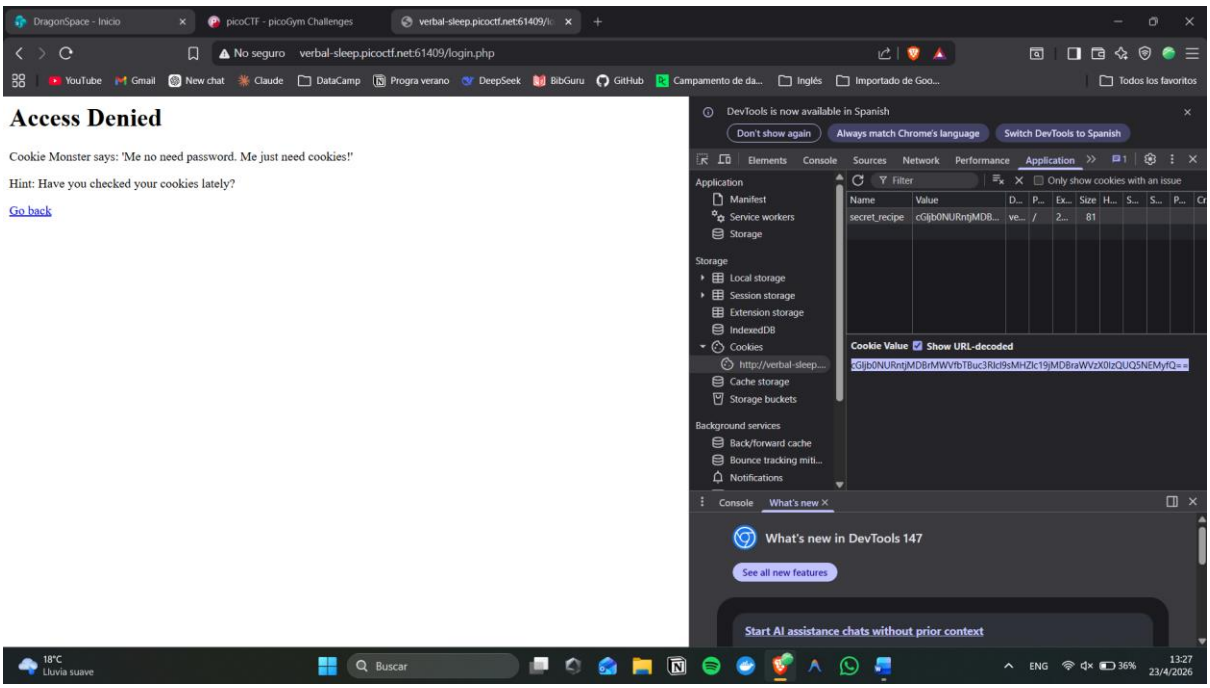
Comparación: SPDP (Ecuador) vs Autoridades GDPR (UE)

Criterio	SPDP -Ecuador	Autoridades GDPR
Nombre del ente	Superintendencia de Protección de Datos Personales (SPDP)	Cada Estado miembro tiene su propia Autoridad de Control nacional. Las más influyentes son la CNIL (Francia), la ICO (Reino Unido), la BfDI (Alemania) y la AEPD (España). Además, existe el Comité Europeo de Protección de Datos (EDPB) que coordina criterios comunes entre todas
Antiguedad operativa	Entre 2024 y 2025 la Superintendencia entró en funcionamiento real, volviéndose plenamente operativa, exigible y sancionable.	Plenamente operativa desde el **25 de mayo de 2018**. Con más de 7 años de enforcement activo, ya cuenta con jurisprudencia consolidada, procedimientos estandarizados y cientos de multas impuestas a empresas de todos los tamaños
Monto de sanciones	Sanciones leves: 0,1% al 0,7% del volumen de negocio. Sanciones graves: 0,7% al 1% del volumen de negocio.	Existen niveles de multas: Infracciones menores (ej: falta de registros): hasta 10 millones de euros o 2% de la facturación global anual, lo que sea mayor. Infracciones graves (ej: violación de principios básicos o derechos del titular): hasta 20 millones de euros o 4% de la facturación global anual, lo que sea mayor.
Enfoque actual	Desde que inició funciones, se ha enfocado en la formación y prevención de riesgos, emitiendo guías y reglamentos de implementación	Enforcement activo y progresivo. Las autoridades ya superaron la fase educativa e investigan de oficio, realizan auditorías sorpresa y sancionan sin necesidad de que un ciudadano presente queja previa. El foco está en Big Tech, IA y transferencias internacionales de datos.
Caso real reciente	En diciembre de 2025, la SPDP impuso sanciones administrativas a LIGAPRO y a la Federación Ecuatoriana de Fútbol por infracciones graves vinculadas al tratamiento de datos personales en las aplicaciones Fan ID y Fan FEF.	En 2023, la autoridad irlandesa (DPC) multó a Meta con €1.200 millones por transferir ilegalmente datos de usuarios europeos a servidores en EE. UU. sin las salvaguardas adecuadas. Es la multa más grande en la historia del GDPR.
Registro de DPO	Las organizaciones deben registrar al delegado de Protección de Datos ante la SPDP dentro de los quince días laborales de su designación	El delegado de Protección de Datos (DPO) debe ser designado y sus datos de contacto publicados y notificados a la autoridad supervisora. En empresas que operan en múltiples países de la UE, se aplica el principio

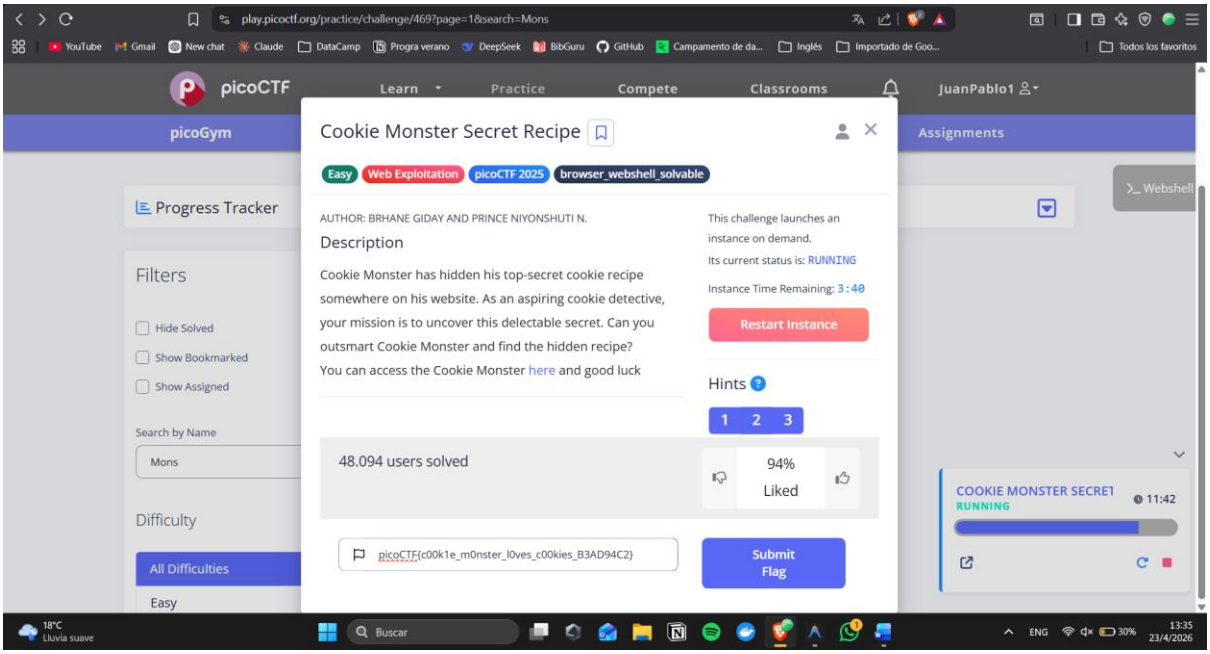
		de "ventanilla única": solo responden ante la autoridad del país donde tienen su sede principal.
Madurez normativa	En etapa de consolidación; aun emitiendo resoluciones y guías técnicas	Sistema completamente maduro con 7+ años de jurisprudencia. Cuenta con guías detalladas del EDPB sobre cada derecho, decenas de miles de casos resueltos, y ha influenciado legislaciones en más de 150 países incluyendo la propia LOPDP de Ecuador.

Tarea 3

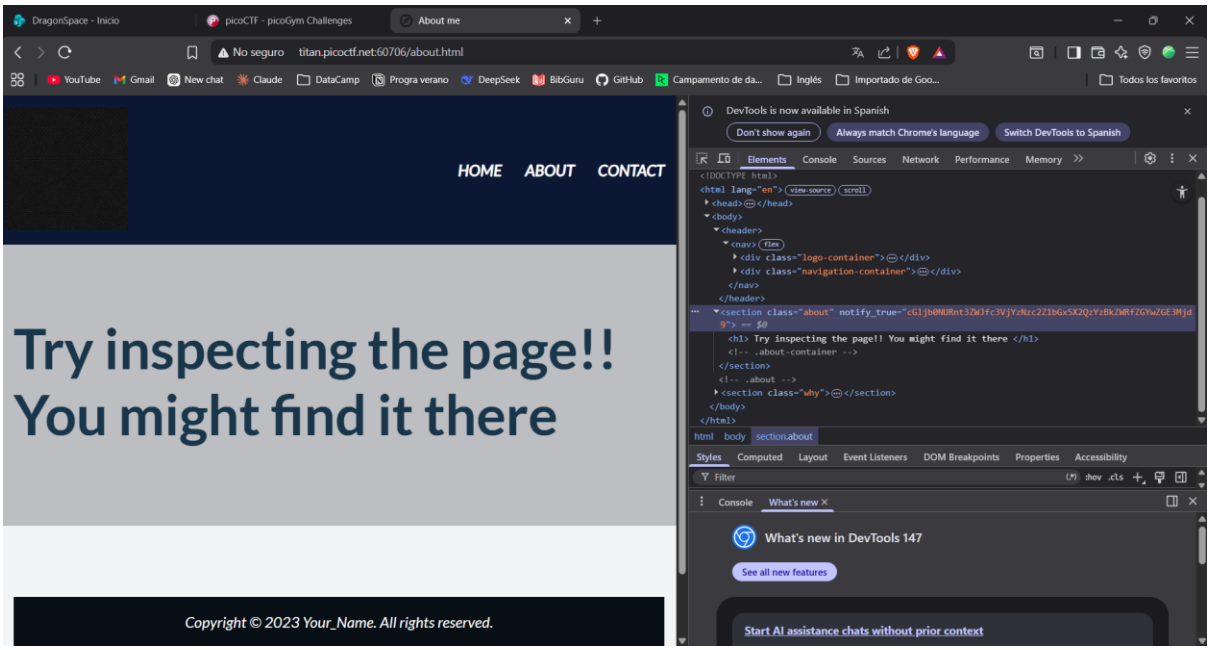
Monster Cookies:



Code: cGljb0NURntjMDBrMWVfbTBuc3Rlcl9sMHZlc19jMDBraWVzX0IzQUQ5NEMyfQ==



Web Decode



<section class="about"
notify_true="cGljb0NURnt3ZWJfc3VjYzNzc2Z1bGx5X2QzYzBkZWRfZGYwZGE3Mjd9">

<h1>

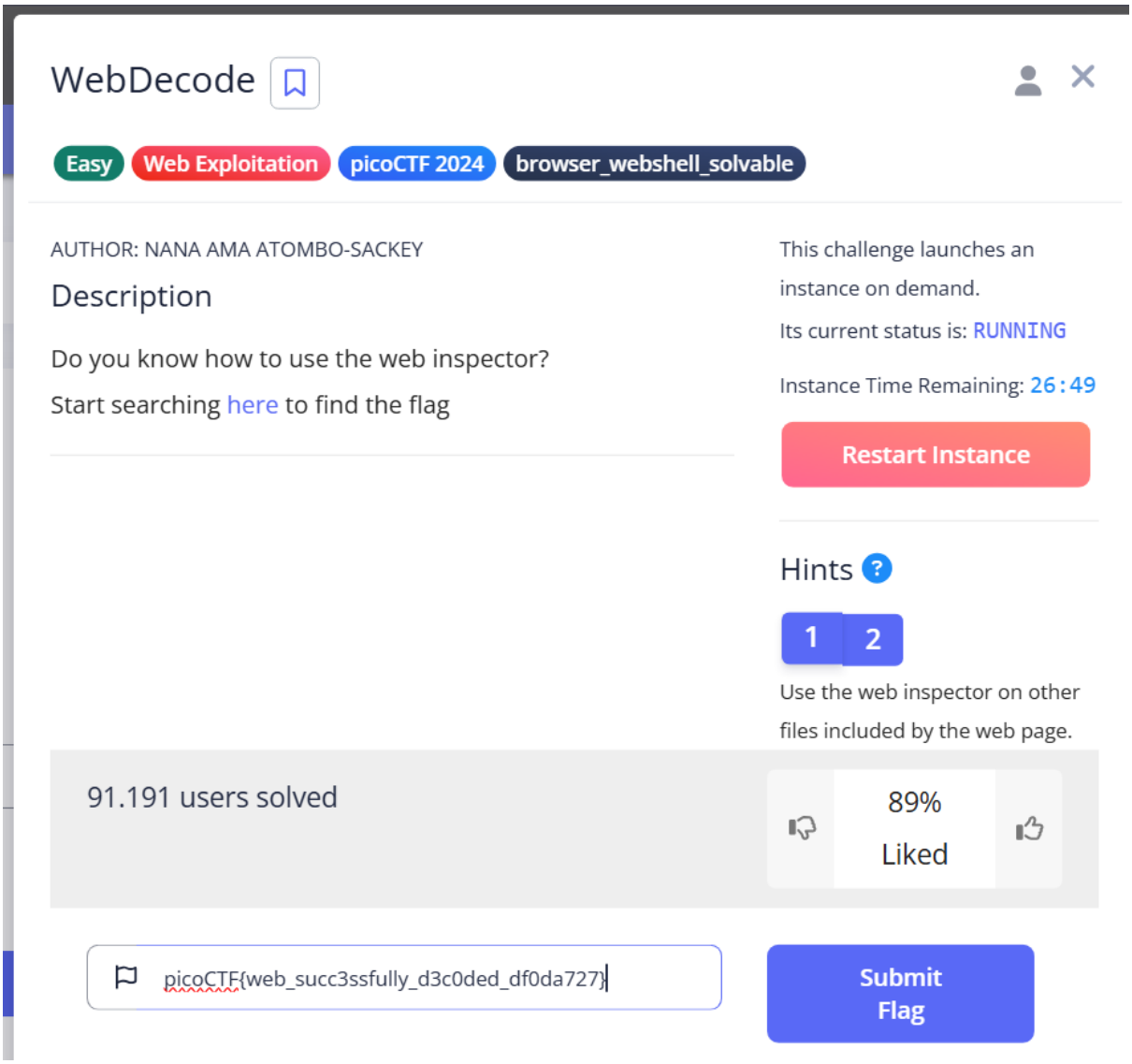
Try inspecting the page!! You might find it there

</h1>

<!-- .about-container -->

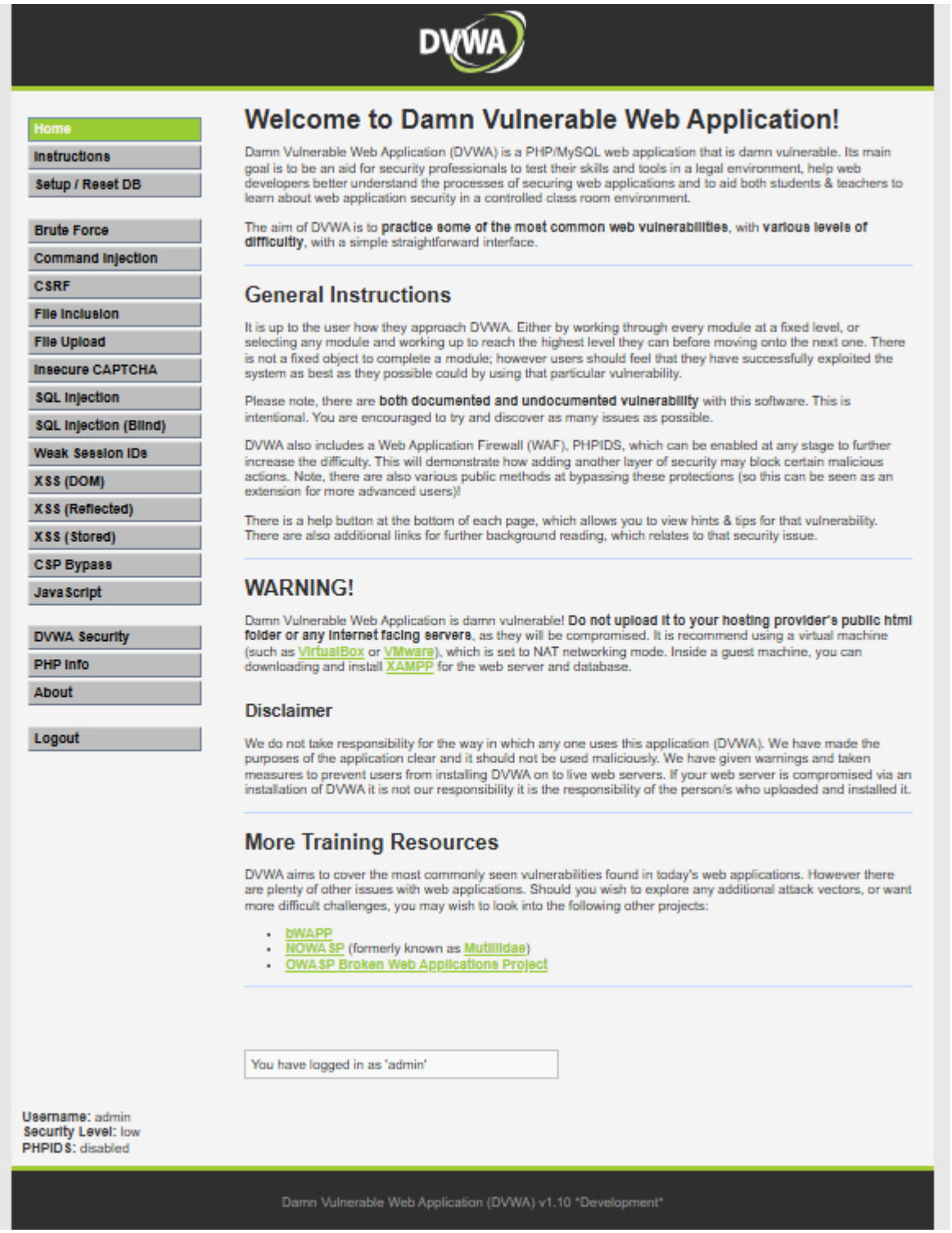
</section>

Flag: picoCTF{web_succ3ssfully_d3c0ded_df0da727}

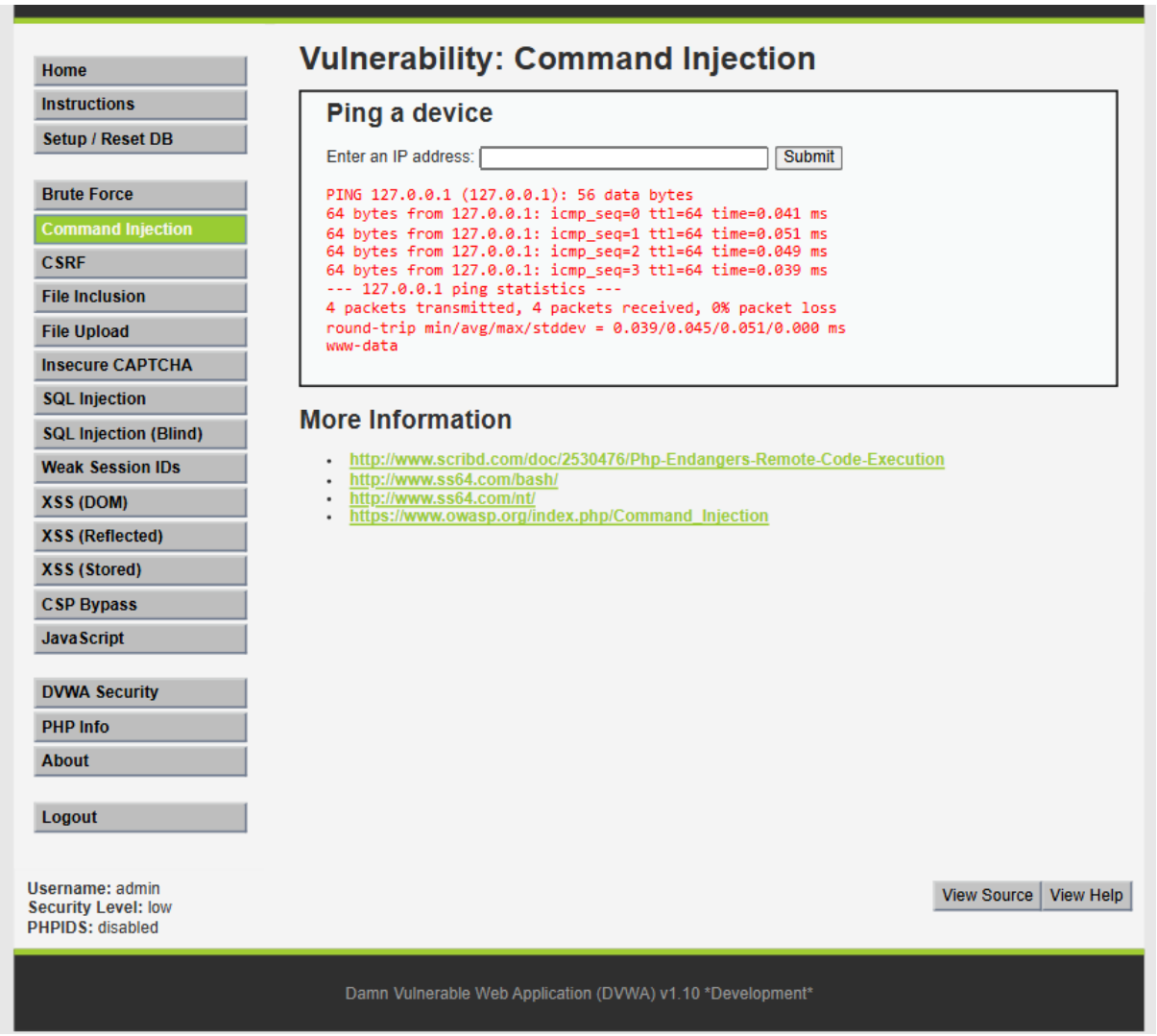


Tarea 4

Contenedor corriendo:



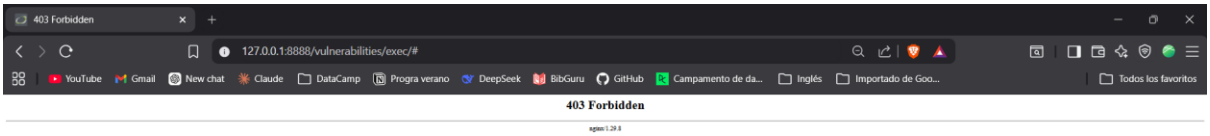
Ejecutar el Command Injection



el resultado de whoami en pantalla.

Al ingresar 127.0.0.1; whoami en el campo de IP, el servidor ejecutó el ping normalmente pero también ejecutó el comando whoami, revelando que el proceso corre como www-data. Esto demuestra que el input del usuario no es sanitizado antes de pasarse al sistema operativo."

Al agregar una regla en el WAF, este es el resultado.



Se desplegó un WAF basado en Nginx en una red Docker privada (dvwa-net) frente a DVWA. Se configuró una regla que intercepta todas las peticiones POST al endpoint /vulnerabilities/exec/ retornando un 403 Forbidden, bloqueando completamente el Command Injection.

Tarea 5

Aviso de privacidad de QuitoCash

Datos que recolectamos

- Datos de identificación: nombre completo, y número de cédula/pasaporte. El propósito es verificar la identidad del usuario y cumplir con obligaciones legales
- Datos de contacto: número de teléfono móvil. Este es el identificador principal para enviar y recibir dinero
- Datos transaccionales: historial de envíos, montos, fechas, y destinatarios. Sirve para procesar operaciones, emitir comprobantes, y prevenir fraude
- Información financiera asociada: cuenta bancaria, tarjeta, o método de pago asociado. Únicamente cuando sea necesario para recargar fondos, retirar dinero, o procesar transferencias
- Datos técnicos y de seguridad: dirección IP, dispositivo utilizado, registros de inicio de sesión y actividad sospechosa. El propósito es proteger la cuenta y detectar fraude
- Datos de comportamiento: patrones de gasto derivados del uso de la app. Se utiliza para las funciones de análisis, predicción de hábitos de gasto, y de recomendación

Propósitos y bases legales del tratamiento

Utilizamos sus datos personales únicamente para finalidades específicas y bajo las bases legales permitidas por el Reglamento General de Protección de Datos (RGPD) y la Ley Orgánica de Protección de Datos (LOPD):

Propósito del tratamiento	Base legal aplicable
Procesar transferencias de dinero, crear y administrar la cuenta del usuario, y permitir el funcionamiento básico de QuitoCash.	**Ejecución de contrato (Art. 7, Num. 5 de la LOPD) (Art. 6, Num. 1b del RGPD)**
Verificar la identidad del usuario, cumplir obligaciones regulatorias, prevenir lavado de activos y atender requerimientos de autoridades competentes.	**Obligación legal (Art. 7, Num. 2 de la LOPD) (Art. 6, Num. 1c; Art. 6, Num. 1e del RGPD)**
Analizar hábitos de gasto mediante herramientas de Inteligencia Artificial para ofrecer predicciones o recomendaciones personalizadas.	**Consentimiento explícito (Art. 7, Num. 1 de la LOPD) (Art. 6, Num. 1f; Art. 6, Num. 1a; Art. 4, Num. 4; Art. 13; Art. 14; Art. 15 del RGPD)**
Proteger la seguridad de la plataforma, detectar actividad sospechosa, prevenir fraudes y mantener la integridad del servicio.	**Interés legítimo (Art. 7, Num. 8 de la LOPD) (Art. 5, Num. 1f; Art. 32; Art. 6, Num. 1b; Art 6, Num. 1f del RGPD)**

Cláusula de Decisiones Automatizadas (IA)

La función de Inteligencia Artificial de QuitoCash se utiliza únicamente para analizar patrones de gasto y generar recomendaciones o predicciones informativas para el usuario.

- **Finalidad informativa:** Nuestro sistema analiza sus categorías de gasto y frecuencias de transacciones para generar visualizaciones, recordatorios de pagos próximos y sugerencias personalizadas de ahorro.
- **Sin efectos jurídicos o significativos:** Estas predicciones y recomendaciones son exclusivamente informativas. No se toma decisiones automatizadas que produzcan efectos legales o significativos sobre el usuario, como negar transferencias, modificar tarifas, bloquear cuentas o determinar acceso a servicios financieros.

- **Supervisión y control:** Usted mantiene el control total sobre su información. En cualquier momento, puede desactivar las funciones de "Predicción de Gastos" desde el menú de configuración de la aplicación, lo cual detendrá el perfilamiento analítico para este fin.

En caso de que QuitoCash llegara a utilizar sistemas automatizados para tomar decisiones que afecten significativamente al usuario, se informará previamente, se solicitará el consentimiento cuando corresponda, y se garantizará el derecho a solicitar intervención humana, expresar su punto de vista e impugnar la decisión.

Derechos de los Usuarios

- **Derecho de acceso:** saber qué datos personales que tenemos

- **Derecho de rectificación:** corregir datos incorrectos o desactualizados

- **Derecho de eliminación:** pedir que se borren sus datos cuando ya no sean necesarios o se retire el consentimiento

- **Derecho a la Portabilidad:** Tienes derecho a recibir tus datos en un formato estructurado y reutilizable

- **Derecho de Oposición:** Puede oponerse al tratamiento de sus datos para fines de predicción de hábitos de consumo en cualquier momento desde la configuración de "Privacidad" en la app.

- **Derecho a retirar el consentimiento:** puede quitar el permiso dado para tratamientos basados en consentimiento

Intercambio de Datos y Transferencia Internacional

No vendemos sus datos. Compartimos información solo con:

- Proveedores de infraestructura en la nube bajo cláusulas contractuales estándar.

- Autoridades competentes bajo requerimiento legal.

Conservación y Seguridad

- **Tiempo:** Conservaremos tus datos mientras dure la relación contractual y por los plazos legales exigidos (generalmente 7-10 años por normativa financiera).

- **Medidas:** Implementamos cifrado de extremo a extremo (AES-256) y anonimización en los sets de entrenamiento de la IA.

Análisis de Minimización de Datos

Para cumplir con el principio de **Data Minimization** (recolectar solo lo estrictamente necesario), QuitoCash no debería solicitar los siguientes datos:

1. **Acceso a la Lista Completa de Contactos:** Aunque la app envía dinero por número de teléfono, no debe acceder a toda la agenda del usuario. Debe permitir la entrada manual o la selección puntual de un contacto, en lugar de almacenar perfiles de personas que no necesariamente son usuarios de la app.
2. **Geolocalización Precisa en Tiempo Real (Background):** Para predecir hábitos de gasto, la IA necesita saber *en qué gasta una persona,* no necesariamente *dónde* está cada minuto del día. Rastrear la ubicación GPS constante es excesivo y riesgoso.
3. **Datos Biométricos Raw (Crudos):** como la app usa FaceID o huella digital, debe apoyarse en los enclaves seguros del sistema operativo (iOS/Android) y nunca almacenar la representación matemática o imagen de la biometría en sus propios servidores.